

CVE-2025-54135 Threat Model

Owner: kasi

Reviewer: Kobra Khanmohammadi

Contributors:

Date Generated: Fri Jun 12 2026



OWASP Threat Dragon

Executive Summary

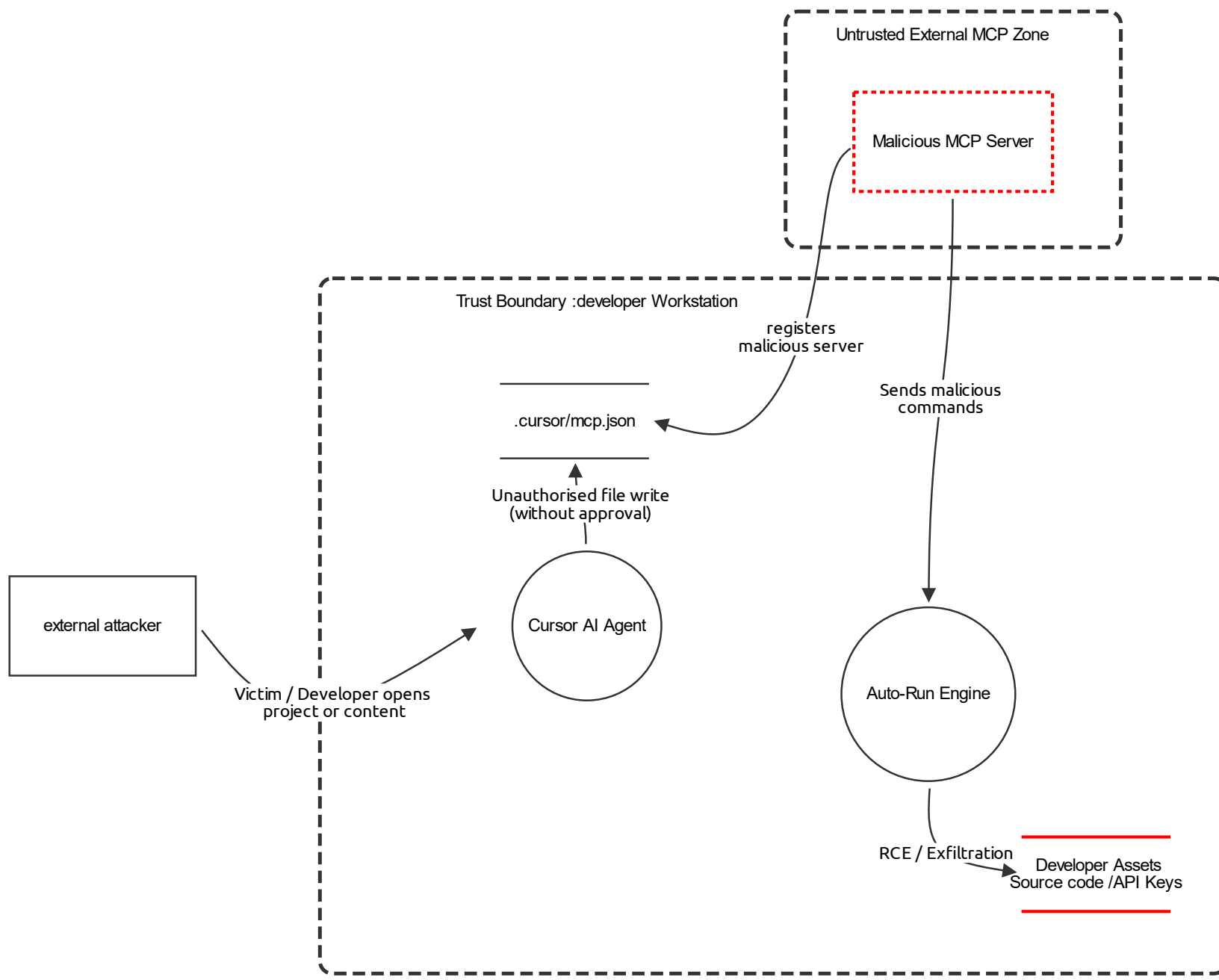
High level system description

End-to-end threat model for Cursor AI RCE vulnerability via indirect prompt injection and MCP config hijack

Summary

Total Threats	5
Total Mitigated	3
Total Open	2
Open / Critical Severity	0
Open / High Severity	2
Open / Medium Severity	0
Open / Low Severity	0

CVE-2025-54135 Attack Flow



CVE-2025-54135 Attack Flow

external attacker (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Cursor AI Agent (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	Indirect Prompt Injection	Tampering	Critical	Mitigated		Attacker-controlled content causes agent to write .cursor/mcp.json without user approval	Upgrade to Cursor v1.3.9; require approval for all sensitive file writes

Auto-Run Engine (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	Remote Code Execution via Malicious MCP	Elevation of privilege	Critical	Mitigated		Malicious MCP server sends OS commands executed automatically	Disable Auto-Run by default; enforce MCP server allowlisting

.cursor/mcp.json (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Unauthorized MCP Config Creation	Tampering	Critical	Mitigated		New dotfile created without approval; bypasses edit-only guard	Treat new dotfile creation same as editing; block without explicit user approval

Developer Assets Source code /API Keys (Store)

Description: such as Source code							
API keys / credentials							
SSH keys / tokens							
Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Credential and Source Code Exfiltration	Information disclosure	High	Open		Post-RCE access to API keys, SSH keys, GitHub tokens, cloud credentials	Rotate all credentials post-incident; use secrets scanning

Malicious MCP Server (Actor) - *Out of Scope*

Reason for out of scope:							
--------------------------	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	MCP Server Spoofing	Spoofing	High	Open		No server identity validation in vulnerable Cursor versions	Implement MCP server signature verification and allowlists

RCE / Exfiltration (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Unauthorised file write (without approval) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Sends malicious commands (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

registers malicious server (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Victim / Developer opens project or content (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------